Anexo D. Registro de riesgos del proyecto

María de los Ángeles Olaya García; Jhon Jairo Cortez Vargas

Servicio Nacional de Aprendizaje (SENA), Programa ADSO-3145556

Instructora: Karol Daniela Correa

12 de octubre de 2026

Anexo D. Registro de riesgos del proyecto

Fuente: 15-project-control/risks.md, elaborado a partir de la auditoría del código del 8 de octubre de 2026. Resumen traducido al español; el original está en inglés.

1. Riesgos activos

• | ID | Riesgo y descripción | Nivel | Estrategia | Responsable y revisión |

• |---|---|---|---|---|

• | R-001 | Suplantación de identidad con cabeceras X-User-. Los servicios aceptan X-User-Id y X-User-Role sin comprobar su origen; quien llegue directo al puerto de un servicio puede hacerse pasar por ADMIN | Crítico | Mitigar | Backend, 31-oct-2026 |

• | R-002 | Llave privada RSA versionada en ms-security. dev-private.pem está en el repositorio y es la llave por defecto; además, la cuenta superadmin se siembra con una contraseña por defecto | Crítico | Mitigar | Backend, 15-oct-2026 |

• | R-003 | CORS abierto con credenciales en el gateway. Se permiten todos los orígenes con credenciales; la variable CORS_ALLOWED_ORIGINS existe pero ningún código la lee | Alto | Mitigar | Backend, 31-oct-2026 |

• | R-004 | Cobertura sin exigir pese al RNF-006. La estrategia pide 80 % de líneas, pero ningún pom.xml tiene JaCoCo; no hay pruebas de contrato, E2E ni de rendimiento y los frontends no tienen pruebas | Alto | Mitigar | QA, 15-nov-2026 |

• | R-005 | ms-user-experience falta en Kubernetes y en el CI. Corre con Docker Compose, pero no tiene Deployment ni PostgreSQL en deploy/k8s/ y no está en la matriz del pipeline | Alto | Evitar | DevOps, 31-oct-2026 |

• | R-006 | Observabilidad decorativa. Prometheus apunta a /actuator/prometheus pero ningún servicio incluye actuator ni micrometer; Grafana no tiene fuentes de datos ni paneles | Alto | Mitigar | DevOps, 15-nov-2026 |

• | R-007 | Desvío entre el ADR-003 y el despliegue. El ADR exige una instancia PostgreSQL con un esquema por servicio, pero Compose y k8s levantan seis servidores independientes; el HistoricalBackfillService une esquemas de bases distintas y no puede funcionar así | Medio | Evitar | Backend, 30-nov-2026 |

• | R-008 | Circuit breaker documentado, no implementado. Sin él, una caída de ms-security deja al gateway sin degradación controlada | Medio | Aceptar | Backend, 15-dic-2026 |

• | R-009 | Firmware de dispositivos fuera de contrato. Hay dos firmwares sin consolidar: uno envía por HTTP plano y falsifica cabeceras ADMIN, y el otro no compila y apunta al servicio y puerto equivocados | Medio | Mitigar | IoT, 15-nov-2026 |

• | R-010 | Frontend sin pruebas ni contratos compartidos. Web y móvil no tienen pruebas, la capa de API está duplicada y diverge, y la app móvil se escribió contra una API que no existe | Medio | Mitigar | Frontend, 30-nov-2026 |

• | R-011 | Documentación que describe cosas inexistentes. Se declara Jenkins como CI (el real es GitHub Actions), hay 6 diagramas UML sin archivo fuente, un puerto errado en local-setup.md y unos 18 archivos referenciados que no existen | Medio | Mitigar | Todo el equipo, 31-oct-2026 |

2. Riesgos cerrados y lecciones aprendidas

• | ID | Riesgo | Resultado |

• |---|---|---|

• | R-012 | Los tokens de ms-security no eran compatibles con el resto de servicios (HS256 con secreto compartido frente a RS256) | Ocurrió. Cerrado el 8-oct-2026: los cinco servicios validan RS256 contra el JWKS de ms-security |

• | R-013 | El outbox de ms-classroom-management nunca publicaba (tabla ausente, falta @EnableScheduling y eventos con UUID aleatorios) | Ocurrió. Cerrado el 8-oct-2026. Lección: una función sin prueba de integración se rompe sin que nadie lo note |

• | R-014 | La cadena de eventos no tenía productores: monitoreo consumía eventos que nadie publicaba | Ocurrió. Cerrado el 8-oct-2026 con el outbox de instalaciones |
• | R-015 | Las métricas en vivo no llegaban al frontend (puntaje siempre 100, temperatura undefined) | Ocurrió. Cerrado el 8-oct-2026 con GET /api/v1/environments/current. Lección: la interfaz no debe asumir campos que ningún endpoint entrega |

3. Relación con el plan de pruebas

Los riesgos R-002 y R-003 se relacionan con el caso SEC-012 (no exponer secretos) y con la sección 11.2 del plan; R-004 y R-010 explican por qué WEB y MOB son casos manuales; R-009 explica por qué IOT-008 está bloqueado. El estado de cada riesgo debe revisarse en la fecha indicada antes de la sustentación.